

TrustZone® Technology Real World Constraints and Use Cases

Don Felton,
TrustZone Software Technical Lead



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 1



What is TrustZone Technology?

- An extension to the ARM® architecture
 - ARMv6z architecture and onwards
 - ARM1176JZ-S™ processor
 - Cortex™-A8 processor
 - Currently in the applications processor space
 - Generally the Cortex-M and Cortex-R families of processors are running a task suite considered wholly secure or non-secure and therefore do not need the dual capability TrustZone adds to the processor
- TrustZone technology gives a totally separated execution environment on the core
- To enable use of this, ARM also has available a suite of software
 - The ARM TrustZone Software



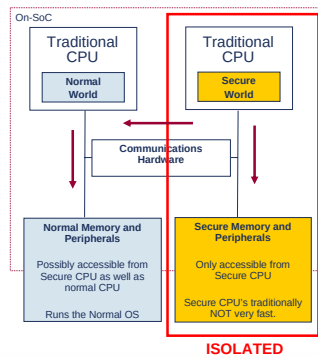
THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 2



Solutions Deployed Today

- Two separate cores
- Communications link between them
 - This communication happens 'outside' the CPU
- Two separate memory and peripheral systems



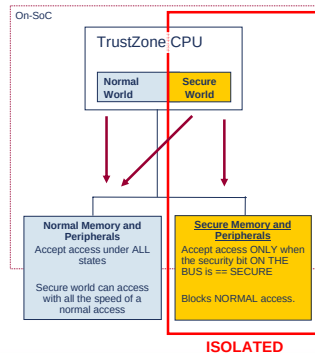
THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 3



Key Aspects of TrustZone Hardware

- The processor understands two operating worlds, Secure and Normal Worlds
 - The MMU understands this and holds two separate states
 - The CPU cache understands this and separates the Secure and Normal data
 - Critical registers are banked
- Processor state is reflected on to the bus
 - Memory and peripherals can now **block** normal access to the Secure materials
- How you gain from this 'isolation' is up to the designer



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 4

ARM

This is an Architectural Solution

- TrustZone technology exists **today**
- The first silicon is starting to appear on the market now
- IP licence for an ARM processor is open to the silicon community
- Anyone can write software to make use of TrustZone technology



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 5

ARM

What to Do with a Secure Environment

- Run code that makes that environment look like a piece of unusual hardware to the outside world:
 - It provides fixed functionality that can never be changed after manufacture
 - It meets a very limited set of requirements
 - If those change you are stuck



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 6

ARM

What to Do with a Secure Environment

- Provide a space where many people can play in the same trusted execution environment:
 - Requires a common interoperability software layer with open standard APIs
 - Already occurred in other devices and has already been solved
 - Found on ePOS terminals, cash machines etc.
 - Visa and MasterCard need download capability but cannot trust each other
 - The TrustZone Software is ARM's solution to this problem, which also includes the Trusted Interpreter based on **GDP/STIP**[1], a security focused bytecode interpreter
 - Requires open specifications for access to that environment
 - This is a new problem
 - ARM has made its solution publicly available, the TrustZone API [2].



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 7

ARM

Security Software

- Secure Bootloader
 - Configure secure memory / peripherals
 - Decrypt / verify code that we are going to run
 - A porting task for each particular design
- TrustZone Software
 - The ARM / Trusted Logic Secure World 'Micro-Kernel'
- Normal World OS Driver Interface
 - OS-specific driver for communicating with the TrustZone technology
- Normal World Client (User Mode) Software
 - Library files exposing high level APIs to clients
 - Applications using the security software – DRM Media Player

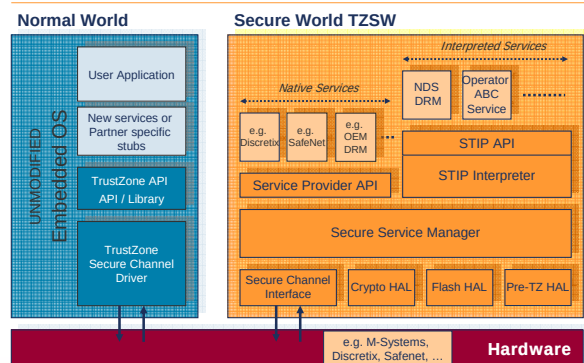


THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 8

ARM

Extensibility with Security Partners



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 9

ARM

What Does All this Mean in an SoC?

- As a manufacturer I need to consider:
 - WHY do I need security?
 - WHAT I am trying to guard against?
 - HOW much I am willing to spend?
- ARM provides some tools to enable solving the technical aspects of these questions
 - But you have to look at the threats facing you and make the appropriate decisions



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 10

ARM

What is a Threat?

- A threat is something making unauthorised access to information
- TrustZone Hardware controls this by having a security state
- TrustZone Software controls this by only allowing some software to run in this security state
- Security State = 0, we are in the Secure world
 - Access granted to all information, secrets and non-secrets
- Security State = 1, we are in the Normal world
 - Access granted to some information, non-secrets only



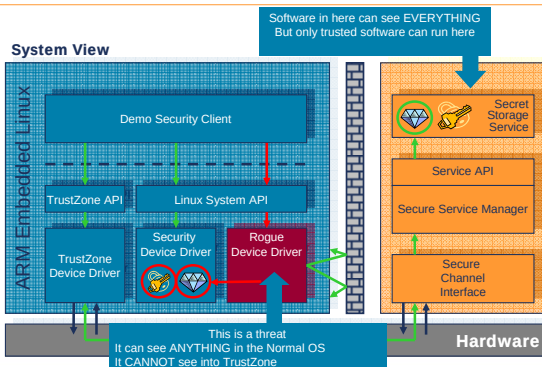
THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 11

ARM

What is a Threat?

System View



THE ARCHITECTURE FOR THE DIGITAL WORLD®

ARM

Making Use of TrustZone Technology

- TrustZone use and secure boot go hand in hand.
- TrustZone Software can be connected to **any** existing **unmodified** rich OS by means of adding a communication driver.
- The TrustZone Software environment is ideal for operations on device specific secrets such as
 - SIMLock status
 - Digital Rights Management
 - Device-specific keys
 - Anything that must be locked to the device rather than the FLASH or SIM
- The TrustZone Software environment can offer facilities to the rich OS that can enhance the rich OS security in two areas
 - Limiting access to keys and secrets
 - Providing a trustable source to prove the OS is loading un-hacked files



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 13

ARM

Designing for TrustZone Technology

- What am I guarding against?
 - Software-based attacks
 - Then I can manipulate my secrets in normal memory devices
 - The additional hardware needed is a TrustZone-aware address map partitioner
 - Hardware-based attacks
 - Then I need to consider physical protection as well as TrustZone technology
 - Hide the signals between secure memory and the SoC
 - Cover connections in Epoxy
 - Don't run connections on the surface of the PCB
 - Use stacked packages
 - Use stacked silicon inside a package
 - Keep TrustZone secrets all on the SoC



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 14

ARM

Software Choices

What are people doing to leverage TrustZone Software



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 15

ARM

Supports Rich OS

- ✓ Boot Securely (easy with TrustZone technology in place)
- ✓ Support validation of file loads against modification attacks
 - Do these, **especially** if supported from TrustZone technology, and we can have a moderately trustable, rich OS
- It's still a **huge** code base, and so is susceptible to errors and exploits
- It may still be running in a vulnerable environment
 - Off-SoC RAM and FLASH
 - Viewable by Normal JTAG mode (TrustZone data is not)
 - Editable by Normal JTAG mode (TrustZone data is not)
- So it is still worth looking at how we can improve upon a rich OS even with its own level of good security



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 16

ARM

Supports the Application Developer

- Step by step...your code into TrustZone Software
- Move the security storage into TrustZone Software
 - This hides keys and secrets from other OS activities
- Move the rights object manipulators into TrustZone Software
 - This prevents overriding of the rights
- Move the key stream handlers into TrustZone Software
 - This makes unauthorized operations using the secrets unavailable to the Normal OS
- Move the codec hardware into TrustZone Software
 - This can close the loop and prevent unauthorized access at any stage, to the decoded and decrypted data – **but** it's not trivial

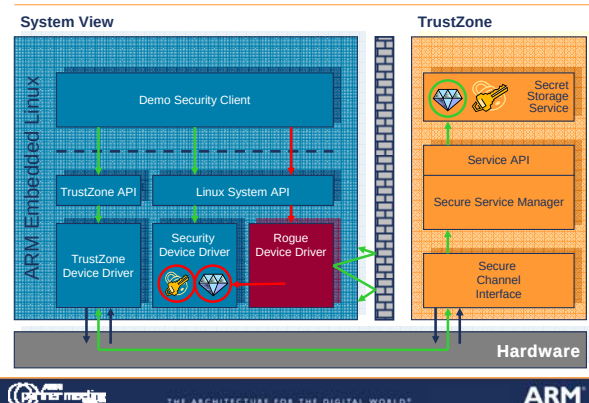


THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 17

ARM

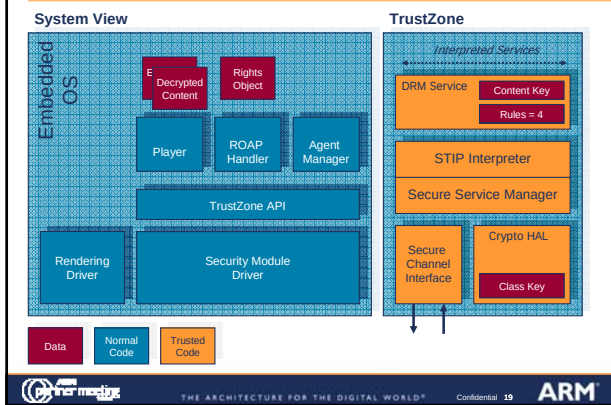
Move Secrets into TrustZone Software



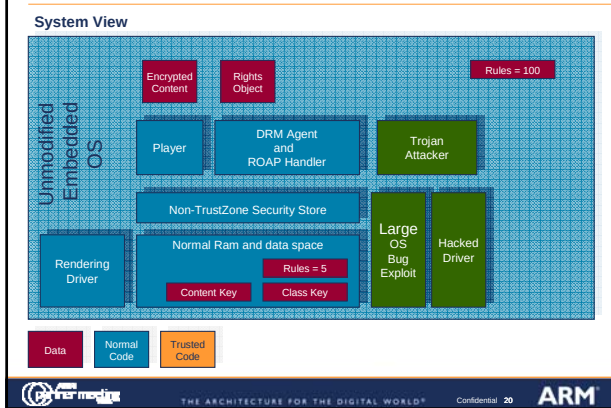
THE ARCHITECTURE FOR THE DIGITAL WORLD®

ARM

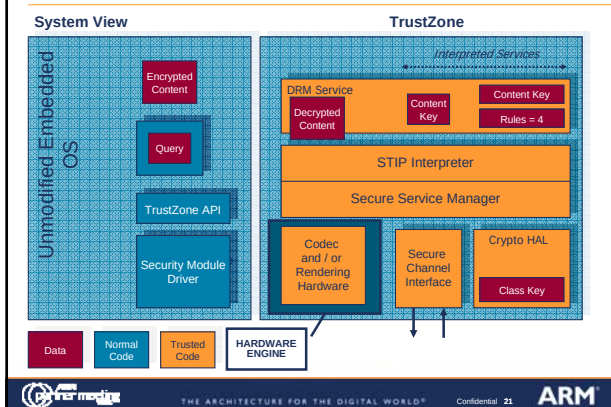
Move Manipulators into TrustZone SW



Without TrustZone Software...



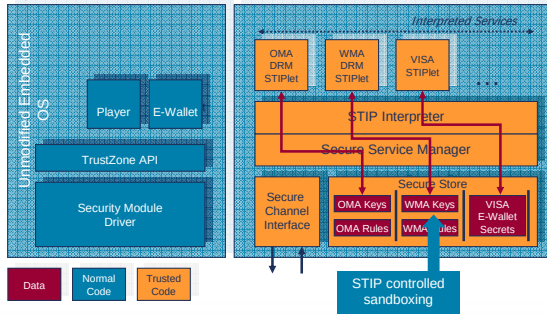
Move Codec into TrustZone Software



STIP Enables Multiple Secure Users

...if you use GDP/STIP, then MANY STIPlets (DRMs) can work safely in TrustZone space

System View



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 22



TrustZone Software

- Some or **all** of this step-by-step approach to using TrustZone Software...
 1. Move the stores and keys
 2. Move the manipulators
 3. Guard the output
- Can be applied to many things
 - SIMLock
 - File use rights
 - Financial software
 - Etc.



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 23



Hardware Choices

Some examples of system design



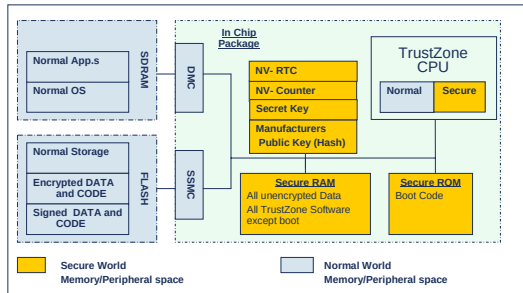
THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 24



Hardware Architectural View

(This is **one** hardware design – there are **many** alternatives)



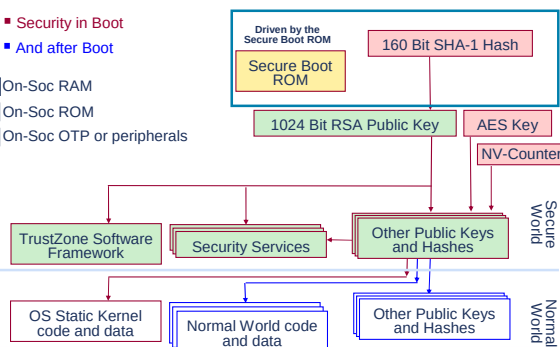
Why These Elements in this System?

- On-SoC ROM
- On-SoC RAM
- Secret key – chip unique
- A hash of the manufacturers public signing key
- An NV-Counter
- An NV-RTC

Why These Elements in this System?

- Security in Boot
- And after Boot

- On-SoC RAM
- On-SoC ROM
- On-SoC OTP or peripherals



On-SoC ROM

- ROM
 - Contains the minimal boot code (or even all the secure code)
 - TrustZone systems always start in Secure World
 - TrustZone systems should always start in this ROM code
 - All code in here is **trusted**, so must be written to a very high standard
- On-SoC
 - So it cannot be replaced to bypass the secure boot
 - So buses leading to it cannot be interfered with or snooped
- What does it do? (typically)
 - It checks a Flash-based RSA public key against the On-SoC hash
 - It loads the next stage of boot to on-SoC RAM
 - It uses that RSA public key to verify the next stage of boot is valid
 - If all is well, it then runs the next stage of code



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 28

ARM

On-SOC RAM

- RAM
 - Code only loaded into here if signed by the maker, or the maker's deputies
 - Data only loaded in here from trusted sources
 - All code in here is **trusted**, so must be written to security standards
 - Normal OS or applications cannot access this memory
- On-SoC
 - So buses leading to it cannot be interfered with or snooped
 - So the RAM device cannot be replaced by an emulator
- What does it do? (typically)
 - Where the TrustZone Security Framework (TZSF) may reside
 - Where any decrypted data is manipulated, hidden from the normal OS
 - It is where any interpreted byte code (STIP) is loaded and run



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 29

ARM

A Hash of Public Key

- Why store a hash?
 - A SHA1 hash requires 160bits of e-fuse
 - An RSA public key (of the same 'security') requires 1024 bits of e-fuse
 - The SHA1 hash **proves** the public key is valid without having to store all the 1024 bits.
 - The **public key** can be used to **prove** a block of code, or data, comes from the device maker
- This key can then also be used to securely verify the integrity of other loaded public keys
 - These other keys can then be safely used for other tasks
 - Each **public key** has a corresponding **private key**
 - Held somewhere very secure by the manufacturer, like in a safe
 - This is the manufacturers **proof** that they are who they say they are to the system



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 30

ARM

A Hash of Public Key

- Public / private key pairs
 - Anyone can have a copy of the **public key**
 - The **public key** just proves that a block of information has been encrypted by the owner of the **paired private key**
 - But the system needs to have proof that it has the **correct public key**
 - Hence the use of the SHA1 hash (aka a message digest)



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 31

ARM

SoC Unique Secret Key and NV-Counter

- A SoC unique secret key
 - A single AES (128 bits) or 3DES (168bits)
 - Allows you to quickly encode data for cheap, but secure, NV-storage off-SoC
 - Prevents other **identical SoCs** from using your stored data
 - They don't have your unique value so cannot decode
 - This stops what is known as a **copy attacks** between devices
- An NV-Counter
 - NV means Non-Volatile
 - So if the device is switched off the value is not lost
 - Each time we store encrypted data we include the counter value
 - And increment the counter
 - This means we can't use data copied from **the same device**
 - The NV-Counter stops what is known as a **replay attack**



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 32

ARM

NV-RTC

- This holds a trusted time reference
 - NV means Non-Volatile
 - So if the device is switched off the value is not lost
 - Required by many DRMs to prove that ROAP licence is valid
 - "You have the right to watch the movie until 3rd October 2005"
 - So DRM needs to know is 3rd of October 2005 later than **now?**
 - Needed for devices that are out of contact with DRM server
- Secure software can make one secure physical RTC source safely usable by many RTC users



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 33

ARM

Optional

- On-SoC ROM
 - Can you trust where you boot from without this?
- On-SoC RAM
 - Are you happy to manipulate your secrets off-SoC?
- Secret key – chip unique
 - Do you need to store secrets linked to the SoC?
- A hash of public RSA key
 - Do you need to verify code loaded by the device?
- An NV-Counter
 - Do you need to block replay attacks?
- An NV-RTC
 - Do you need to trust the time?
- All of it is optional
 - If you do not compromise security by removing a particular element

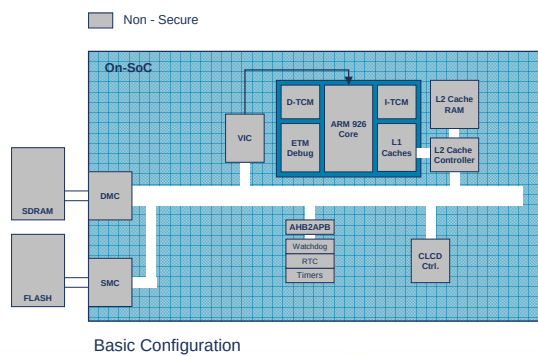


THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 34



Pre-TrustZone HW Architecture

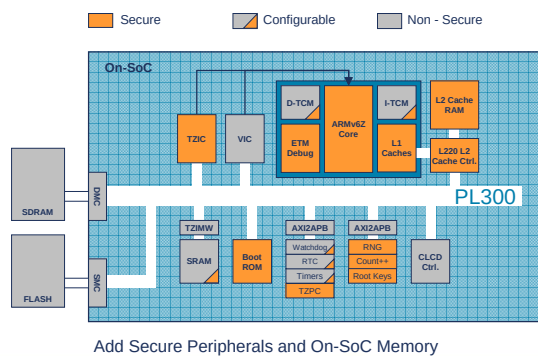


THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 35



TrustZone HW Architecture

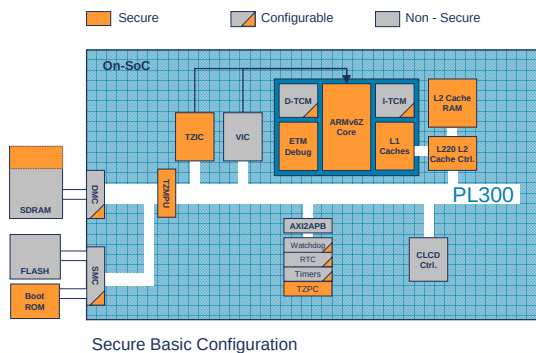


THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 36



But You Could Have Built this....



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 27

ARM

What's Happening Today?

What is ARM doing with TrustZone technology
Who else is doing what with TrustZone technology



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 28

ARM

What's Happening Today?

ARM TrustZone Software

- ARM made available a software environment for use in TrustZone systems, to allow easy take up of the new hardware security
 - We have tried to keep the TrustZone environment as open as possible
 - ARM announced the TrustZone Software API as an open standard for access to software in the TrustZone environment
 - ARM TrustZone Software adopted GDP/STIP
 - An **open** solution to the issue of many players wanting to use the security environment, but only limited trust between those users



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 29

ARM

What's Happening Today?

ARM Hardware

- New IP from ARM to allow more flexible demarcation
 - ARM TrustZone Memory Protection Unit (PL380 TZ MPU)
 - Allows you to define memory regions as
 - Secure access
 - Read write, read only or no access
 - Non-secure accessible
 - Read write, read only or no access
 - That means you can declare your RAM based rich OS code and static data as read only
 - That's just like putting it in ROM that runs with the speed of RAM!



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 40



What's Happening Today?

- 20+ silicon licences for TrustZone technology-enabled processor designs
- A large number of SoCs in various stages of production
 - TrustZone technology-capable cores appearing on phones Q1 2007 from leading OEMs
 - Silicon already available from Philips, Samsung and others
 - The TI OMAP platform also announced the use of the TrustZone Software in currently shipping platforms
 - Other licensees of the TrustZone Software include major consumer electronics companies



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 41



Who is Using TrustZone Technology?

- **DRM manufacturers** using TrustZone Software environment to meet their requirements for security and flexibility
 - NDS
 - Beep Science
 - Philips
 - Viaccess
 - And others
- They are using TrustZone Software as a hidden place to perform any or all of their decrypt, key and rights management operations



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 42



Who is Using TrustZone Technology?

- **Crypto security hardware manufacturers** recognize that consistent APIs allow them to sell their hardware solutions more easily
- TrustZone Software exposes standard HALs internally and yet can reflect their proprietary APIs to the rich OS
- M-Systems, Safenet and Discretix are partners currently working with ARM to explore collaborative solutions
- And they get the bonus that some operations they had to do in software and not hardware (e.g. for RSA key processing) can now be done in a secure, hidden environment



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 43



Who is Using TrustZone Technology?

- **OS vendors** recognize the desirability of consistent APIs
- They are working on exposing functionality to tie their security (that is bound to the Flash contents) to the secrets locked to the SoC through TrustZone technology
- Activity is confidential but we would encourage interaction with all the major OS players



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 44



Who is Using TrustZone Technology?

- **Network Operators** see TrustZone technology solving many problems
- Long-term goal to close the loopholes in IMEI and SIMlock
- TrustZone technology can be designed to block those attacks
- Work in 3G and ETSI on is underway to provide
 - Secure links between SIM and mobile device
 - Only works if the SIM can trust the part of the device it is talking to
 - Improved SIMlock
 - Much of this is solved by the secure link, and by placing the rights management code into TrustZone Software
 - IMEI protocols that will allow for end-to-end signed messaging
 - The issue is the vulnerability of the large GSM Protocol Stack
 - If the message is signed by a trusted party on the device, then this issue goes away



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 45



References

[1] GDP/STIP is a Global Platform Specification

See: <http://www.globalplatform.org/specificationview.asp?id=device>

[2] The TrustZone API is an publicly available specification, that is open to all to use.

It can be downloaded from the ARM website at

http://www.arm.com/products/esd/trustzone_apidownload.html.

More general overview information can be found at

<http://www.arm.com/trustzone>.

[3] PKCS#11 is an open standard managed by the RSA Security Inc.

It is fully described as the RSA Security Inc. PKCS #11 Cryptographic Token Interface (Cryptoki)

[4] POSIX is controlled by the IEEE Standards Association and The Open Group.



THE ARCHITECTURE FOR THE DIGITAL WORLD®

Confidential 46

